# Informe 4 · Controles de seguridad

**Sistema integrado de eventos laborales (JML) · Andina Servicios S.A.S. (empresa ficticia, datos ficticios)**
Politécnico Grancolombiano · Gerencia de Proyectos en Seguridad de la Información · Grupo D01
Auditoría del 24 al 25 de octubre de 2026 · rama `auditoria/entrega` · commit `c6e6490` · generado el 25/10/2026

## 1. Cómo leer este informe

Cada control se presenta con tres cosas: **qué promete** el SRS o el ADR, **cómo se comprobó** y **qué pasó cuando se quitó**. Un control que ninguna prueba nota que falta no está verificado, aunque el código parezca correcto. Por eso cada fila cita una prueba que se rompe al quitar el control, o una medición reproducible.

Resultado global: **36 hallazgos** (0 Críticos, 0 Altos, 15 Medios, 15 Bajos, 6 Informativos), **score global 1,3 de 100** (aceptable) con **144 controles de ASVS verificados**. El score se reporta junto a ese número: con pocos controles probados, un score bajo no significaría nada.

## 2. Confidencialidad

| Control | Promesa | Comprobación | Resultado |
|---|---|---|---|
| Campos restringidos solo en `solicitud_restringida` | Motivo de retiro y descripción de emergencia nunca van a GLPI, logs, dashboard ni fichas (RD-05, invariante 5) | Centinela escrito en el campo y buscado en 31 240 tramas hacia GLPI (0), en el tramo cifrado (0) y en la ficha del técnico (404 al detalle) | **Verificado** (CA-10) |
| Filtro de logs | Los campos `password`, `token`, `totp`, `secret`, `motivo` y `descripcion` no se registran | Propiedad de Hypothesis, 1 000 casos, y el defecto sembrado «filtro roto» la hace fallar. Encontró que `contraseña` y `descripción` con acento pasaban | **Verificado**; B-21 corregido |
| TLS externo | TLS 1.2 o superior, solo AEAD, HSTS (RS-01) | `testssl.sh`: solo TLS 1.2 y 1.3, 0 de 19 vulnerabilidades; 10 de 10 saludos en TLS 1.3 | **Verificado** |
| Secretos | Solo en `/run/secrets`, nunca en código, `.env` versionado ni GLPI (invariante 10) | `gitleaks` sobre el historial: 0; el gancho `pre-commit` rechaza un secreto sembrado | **Verificado**; los 5 avisos del árbol están en rutas ignoradas por git |
| Supabase aislada | Sin `GRANT` a `anon` ni `authenticated`; RLS activo sin políticas; `service_role` solo en `admin-usuarios` | Paridad de catálogo con el Supabase de desarrollo (solo lectura); prueba del compose para `service_role` | **Verificado**; B-23: las nueve tablas de Django no tenían RLS, corregido en la migración 0006 (**falta aplicarla en Supabase**) |
| Soporte de vinculación | Solo PDF por firma, <= 20 MB, nombre aleatorio, nunca abierto ni servido | PDF políglota, 20 MB exactos y +1, nombre con `../` y `\x00` | **Verificado**; B-22 aceptado: un PDF políglota pasa por diseño (sin antivirus, ADR-021) |
| Tokens de GLPI | No viajan en claro dentro del equipo | 382 `App-Token`, 378 `Session-Token` y 4 `user_token` legibles en la red `app` | **No cumple** -> B-32 (Medio) |
| Mínimo privilegio de la cuenta de servicio | El perfil se limita a las operaciones de RI-02 | Perfil real medido con la propia cuenta: puede además borrar y purgar tickets | **Parcial** -> B-35 |

## 3. Integridad

| Control | Promesa | Comprobación | Resultado |
|---|---|---|---|
| Auditoría encadenada | `hash = SHA-256(hash_anterior \|\| contenido)`, solo inserción (RD-02, RD-03) | Vector de referencia fijo; `UPDATE` y `DELETE` denegados a `app_backend`; el defecto «sin REVOKE» hace fallar dos pruebas | **Verificado** |
| Verificación de la cadena | El Auditor la recorre completa y queda registrada (RF-36) | Cadena válida tras 414 registros, tras una restauración y tras 6 586 de la carga; alterar un registro la rompe (CA-09) | **Verificado** |
| Solicitud aprobada inmutable | Disparador en la base (RF-14) | Defecto «sin disparador» sembrado: detectado por `test_RF_14` | **Verificado** |

| Control | Promesa | Comprobación | Resultado |
|---|---|---|---|
| Deduplicación en la base | Índice único parcial sobre (colaborador, tipo) en los cuatro estados abiertos | Dos conexiones concurrentes: una gana | **Verificado** |
| Decisiones simultáneas | Dos RRHH no deciden la misma solicitud | `select_for_update`; sin él la prueba se rompe | **Verificado** |
| Rastro exacto de la cadena | Cada evento lleva sus claves y valores (RF-35) | Rastro completo de un ING y un RET comparado clave por clave (`test_rastro_exacto.py`) | **Verificado** |
| Cadena de suministro | Dependencias e imágenes sin vulnerabilidades explotables (RS-11, RS-18) | `pip-audit` 0; imagen propia 0 CRÍTICAS; 0 de 139 CVE en el catálogo KEV; SBOM CycloneDX de 115 componentes | **Verificado**; B-31: las imágenes de terceros conservan CRÍTICAS sin parche, con exención escrita |
| Sin acciones sobre directorios | Ningún código llama a LDAP, Graph ni Samba (invariante 1) | Búsqueda en el código y las dependencias; prueba `test_tabla_II_adr_003_004_010_019` | **Verificado** |

## 4. Autenticidad y autorización

| Control | Promesa | Comprobación | Resultado |
|---|---|---|---|
| Doble factor | La sesión se crea solo después de verificar el TOTP (AAL2) (RF-01) | Un código usado no vuelve a servir; un desafío ajeno no entra; el defecto «segundo uso» se detecta | **Verificado** |
| Sin tokens guardados | Los tokens de Supabase no se guardan (invariante 9) | Tras llegar a AAL2 no queda ningún token ni sesión de Supabase | **Verificado**; B-28: el JWT se lee sin verificar la firma (riesgo acotado por TLS `verify-full`) |
| Errores genéricos | El inicio de sesión no distingue «no existe» de «clave mala» (RS-08) | Pruebas de identidad y 14 cabeceras hostiles | **Verificado** |
| Sesión | 30 minutos de inactividad o 8 horas, con rotación del identificador (RF-04) | Pruebas de ingreso web | **Verificado** |
| Autorización por rol | Cada vista verifica el rol (RF-03) | **440 celdas** (22 rutas × 2 métodos × 10 roles) generadas desde el SRS: 0 resultados distintos del esperado; 403 frente a 404 comprobado | **Verificado**; una excepción documentada: B-26 (el Auditor no lee solicitudes) |
| Denegaciones registradas | Todo acceso denegado deja evento (A09) | 118 celdas de denegación -> un evento cada una. Encontró que **no dejaban rastro** | **Verificado**; B-25 corregido |
| IDOR, asignación masiva y CSRF | Respuesta idéntica a un id inexistente; campos extra ignorados | Pruebas con control positivo | **Verificado** |
| Roles incompatibles | RRHH, técnicos, Administrador y Auditor no se mezclan (RF-05) | Los pares de la Tabla IV del Excel contra `ROLES_INCOMPATIBLES`: coinciden exactamente | **Verificado** |
| Autoaprobación | RRHH no decide sobre sí misma (RF-15) | Pruebas de dominio y de aplicación | **Verificado** |

## 5. Disponibilidad y resiliencia

| Control | Meta | Medido | Resultado |
|---|---|---|---|
| Detección de GLPI caído | < 120 s (RNF-01) | 63 s | **Cumple** |
| Detección de la base caída | < 120 s | 43 s | **Cumple** |
| Restauración desde respaldo | RTO 4 h | 19 s (21 s con comprobaciones); 24 tablas con las mismas filas y la misma cabeza de la cadena | **Cumple** |
| Rendimiento (RNF-06) | p95 < 800 ms por página; dashboard < 2 s | p95 de 466 a 649 ms; dashboard 786 ms (1 440 peticiones, 0 errores) | **Cumple** a 20 vueltas; una corrida de 10 vueltas dio 6 páginas sobre 800 ms (se conserva) |
| GLPI caído no pierde solicitudes | Bandeja de salida con reintentos e idempotencia (RF-18) | Pruebas de resiliencia y Gherkin | **Cumple**; B-20 corregido |
| Proceso único de `gunicorn` | Sin punto único de falla | Un proceso con 8 hilos | **Aceptable a esta escala**; B-06, decisión del equipo |
| Límite de ritmo del WAF | Frenar a un escáner sin frenar a una persona (RS-08) | La tercera página en menos de un segundo recibe 429; varios seguidos banean la IP una hora | **Parcial** -> B-36 (Medio) |

## 6. Defensa en el borde (BunkerWeb)

| Control | Resultado |
|---|---|
| ModSecurity + OWASP CRS 4 en modo bloqueo | `infra/waf/pruebas.sh`: tráfico normal 200 y ataques 403, en `app.*` y `glpi.*`. Un ataque de inyección SQL se bloquea (403) y la misma operación legítima da 200 |
| Exclusiones del CRS | 0 exclusiones, 0 pruebas necesarias |
| Solo `bunkerweb` publica puertos | 28 comprobaciones de la matriz de puertos, 0 diferencias. Excepción no escrita: Grafana y fluent-bit en `127.0.0.1` (B-27) |
| API interna de BunkerWeb | Responde en la red `app` (B-29), pero exige `API_TOKEN`: con y sin token, a dos rutas, desde `app`, las 6 combinaciones terminan en reinicio de conexión |
| Reportería | Un ataque aparece clasificado `waf` en Loki en el mismo segundo del bloqueo (CA-21, parte local) |
| Endurecimiento de contenedores (CIS) | 42 comprobaciones, 12 avisos -> B-33. Ya no fallan SELinux (5.2), memoria (5.10) ni nuevos privilegios (5.25), que sí fallaban en la Entrega 3; AppArmor (5.1) sigue en aviso. Solo se midieron las secciones de imágenes y de contenedores |

## 7. Criterios de aceptación (CA-01 a CA-21)

| CA | Criterio | Estado | Evidencia |
|---|---|---|---|
| CA-01 | Deduplicación: el segundo intento se rechaza | cumple | evidencias/funcionales/F1-02-INTEGRACION |
| CA-02 | Aprobación: sin decisión de RRHH no hay tickets | cumple | evidencias/funcionales/ANEXO-A-JUNIT |
| CA-03 | Enrutamiento a las colas correctas | cumple | evidencias/funcionales/F1-03-GLPI-REAL-3 |
| CA-04 | Tickets programados nacen «En espera» | cumple | evidencias/funcionales/F1-03-GLPI-REAL-3 |
| CA-05 | Flujo ING completo hasta cerrada | cumple | evidencias/funcionales/ANEXO-A-JUNIT |
| CA-06 | EMG: prioridad «Muy alta» y SLA de 1 hora | cumple | evidencias/funcionales/F1-03-GLPI-REAL-3 |
| CA-07 | Resiliencia con GLPI detenido | cumple | evidencias/disponibilidad/F7-08-DETECCION-GLPI |
| CA-08 | Cierre verificado: sin solución no cierra | cumple | evidencias/funcionales/ANEXO-A-JUNIT |
| CA-09 | Alterar la auditoría hace fallar la verificación | cumple | evidencias/funcionales/F1-02-INTEGRACION |
| CA-10 | El centinela del motivo no llega a GLPI | cumple | evidencias/trafico/F7-04-CAPTURA-TRAFICO |
| CA-11 | Detección de la caída de GLPI y de la base | cumple | evidencias/disponibilidad/F7-08-DETECCION-BASE |
| CA-12 | ZAP y sqlmap sin hallazgo | cumple | evidencias/vulnerabilidades/F6-04-SQLMAP-NIVEL5 |
| CA-13 | La clave pública de Supabase no lee tablas | parcial | catálogo verificado en F3-PAR; la petición a la Data API quedó omitida (S-38) |
| CA-14 | Contraseña correcta sin TOTP no entra | cumple | evidencias/controles-positivos/F3-U01 |
| CA-15 | El dashboard coincide con su oráculo | cumple | evidencias/disponibilidad/F9-05-RENDIMIENTO-20V |
| CA-16 | Búsqueda y ficha correctas | cumple | evidencias/funcionales/ANEXO-A-JUNIT |
| CA-17 | `import-linter` falla si se rompe la arquitectura | cumple | evidencias/estaticos/F2-02-RUFF-MYPY-IMPORTS |
| CA-18 | Soporte de vinculación: solo PDF válido | cumple | evidencias/controles-positivos/F3-U02 |
| CA-19 | El ticket AD lista cada recurso con ruta, serie, perfil y grupo | cumple | evidencias/funcionales/ANEXO-A-JUNIT |
| CA-20 | `pruebas.sh` devuelve 200 y 403 donde corresponde | cumple | evidencias/vulnerabilidades/F6-01-PRUEBAS-SH |

| CA | Criterio | Estado | Evidencia |
|---|---|---|---|
| CA-21 | Un ataque aparece clasificado `waf` en menos de 2 minutos | cumple | evidencias/disponibilidad/CA-21-REPORTERIA-WAF |

CA-21 cumple en su parte local; que los datos queden en Blob es de Azure y no se pudo comprobar. CA-13 queda parcial por la petición a la Data API del proyecto de desarrollo, que no se hizo (Supabase en solo lectura).

## 8. ASVS 5.0 (nivel 1 y 2)

253 requisitos del CSV oficial: **144 verificados, 36 parciales, 19 pendientes y 54 que no aplican** con motivo escrito. Los verificados son el **72,4 %** de los aplicables (199). De los 19 pendientes, 12 son la política mínima de contraseña de Supabase (acción humana en el panel: B-10), 5 son el certificado de producción y el TLS del borde (Let's Encrypt en Azure) y 2 son un inventario criptográfico que no está escrito. Los 36 parciales se reparten entre la verificación de firma, `exp` e `iss` del JWT (B-28, 11), el tramo worker->GLPI en claro (N-1) y la API de BunkerWeb en la red `app` (N-2), el PDF políglota aceptado (B-22), las vulnerabilidades del sistema operativo sin parche (B-18), la copia inmutable en Azure Blob y el registro abierto deshabilitado con recuperación de cuenta por el Administrador. La revisión del 10 % de la clasificación por una segunda persona sigue pendiente `[PENDIENTE: segunda persona]`. Archivo: `asvs-l2.csv`.

## 9. El Anexo A (Excel «AnexoA. Tablas.xlsx»)

Las 18 hojas (157 filas) se contrastaron una a una con el SRS y con el sistema.

| Resultado | Filas |
|---|---|
| Cumple | 138 |
| Parcial | 9 |
| No verificable en local | 10 |
| Falla | 0 |

Parciales: el rol Solicitante del Excel promete crear y eliminar cuentas y mandar correos (el SRS y ADR-019 lo prohíben: es un error del Excel, no del sistema); el Auditor no lee solicitudes (B-26); la cuenta de servicio puede borrar tickets (B-35); WCAG AA sin evaluación manual (RI-01); Supabase Auth real no ejercido (RI-04); y tres ADR que dependen de Azure (002, 005, 009). El Excel además está desfasado respecto al SRS v2.4 en la Tabla I, los ADR-14, 28, 29 y 30, RF-06 y RI-03. Informe completo: `verificacion-anexo-a-excel.md` y `anexo-a-matriz.csv`.

## 10. Controles que no existían y se agregaron

| Control nuevo | Por qué |
|---|---|
| Contraste de 3:1 en campos y barras del gráfico | RI-01 pedía WCAG AA y no lo medía nadie (B-34) |
| Registro de cada acceso denegado | Una denegación no dejaba rastro (B-25) |
| Filtro de logs con acentos | `contraseña` y `descripción` pasaban (B-21) |
| RLS en las tablas de Django | Contra el invariante 8 (B-23) |
| Aviso de servicio no disponible en el segundo factor | La página respondía 500 (B-24) |
| Aislamiento de errores en la sincronización y la bandeja | Una solicitud mala detenía a todas (B-19, B-20) |
| Fallo ruidoso si GLPI rechaza el vencimiento | El ticket quedaba sin vencimiento en silencio (B-17) |
| Gancho `pre-commit` con `gitleaks` y `ruff` | Un secreto llegaba al historial antes de la CI (B-07) |